

UNIVERSIDAD PERUANA UNIÓN
Facultad de Ingeniería y Arquitectura
Escuela Profesional de Ingeniería de Sistemas — Filial Juliaca

PROYECTO DE TESIS / PROYECTO INTEGRADOR

HemoScan Andino

Sistema no invasivo de tamizaje de anemia infantil con fusión óptica
multisensor y autocalibración por altitud

**Entregable 2 de Infraestructura (CE0321) — Planificación de
Seguridad**

Juliaca, Puno, Perú
Julio de 2026

Índice

Resumen Ejecutivo	3
1. Identificación de Activos Críticos	5
1.1 Metodología de identificación y clasificación	5
1.2 Inventario de activos críticos	5
1.3 Síntesis de activos de máxima criticidad	12
2. Análisis de Riesgos (ISO 27005 / NIST)	12
2.1 Metodología	12
2.2 Taxonomía de fuentes de amenaza consideradas	13
2.3 Matriz de riesgos de seguridad de la información (riesgo inherente)	13
2.4 Mapa de calor de riesgo inherente (probabilidad × impacto)	22
2.5 Priorización y estrategia de tratamiento	22
3. Políticas de Seguridad	23
3.1 Política de Control de Accesos	23
3.2 Política de Protección de Datos Personales y de Salud de Menores de Edad	24
3.3 Política de Gestión Criptográfica	25
3.4 Política de Seguridad de Dispositivos de Campo y Movilidad	25
3.5 Política de Copias de Seguridad y Continuidad Operativa	26
3.6 Política de Gestión de Incidentes de Seguridad	26
3.7 Política de Desarrollo Seguro (Secure SDLC)	27
3.8 Política de Uso Aceptable y Concientización en Seguridad	27
3.9 Política de Gobernanza de Inteligencia Artificial y Trazabilidad	28
3.10 Política de Gestión de Terceros y Cadena de Suministro	28
3.11 Ética profesional (Código de Ética y Conducta Profesional de la ACM) y responsabilidad social	28
3.12 Precondición legal previa a la operación con datos reales (síntesis de validaciones pendientes de las Políticas 3.2 y 3.6)	29
4. Roles y Responsabilidades	30
4.1 Estructura de gobierno de seguridad	30
4.2 Matriz RACI de procesos de seguridad	31
4.3 Justificación de la asignación de roles	33
Anexos	34
Anexo A — Matriz de riesgos completa: tratamiento y riesgo residual estimado	34
Anexo B — Referencias normativas y de estándares	36
Anexo D — Checklist de seguridad de Fase 0 (operacionaliza el paquete EDT 2.3 del Plan de Gestión)	37
Material complementario de referencia (fuera del cuerpo evaluable)	39
Anexo C — Glosario de términos y siglas de seguridad	39
Anexo E — Índice de diagramas y figuras presentados en el cuerpo del documento	40
Nota interna de cobertura frente a la rúbrica (fuera del cuerpo evaluable)	40

Entregable N.º 8 — Planificación de Seguridad (*Octavo entregable consecutivo del proyecto HemoScan Andino. Corresponde al Entregable N.º 2 de la competencia CE032 — Área A: Infraestructura Tecnológica; utiliza una numeración de entregable propia y distinta de la de los Entregables N.º 1-4 del Área B — Gestión de TI— y N.º 5 del Área C — Ingeniería de Software— ya presentados, aunque continúa la secuencia documental global del proyecto*)

Área de competencia: Área A — Infraestructura Tecnológica **Competencia:** CE032 — Gestión de la Seguridad de la Información **Evidencia que cubre este documento:** CE0321 — Planificación de Seguridad (identificación de activos críticos, análisis de riesgos según ISO 27005/NIST, políticas de seguridad y roles y responsabilidades)

Organización diagnosticada (caso ilustrativo y representativo): Microred de Salud Altiplano-Puno

Integrantes del equipo:

N.º	Integrante	Rol / Área de competencia
1	(Integrante 1, Líder de Infraestructura Tecnológica – nombre por completar)	CE03 — Infraestructura Tecnológica (red, seguridad, centro de datos) — responsable principal de este entregable
2	(Integrante 2, Líder de Gestión de TI – nombre por completar)	CE01 — Gestión de TI (diagnóstico, business case, plan de gestión, procesos)
3	(Integrante 3, Líder de Ingeniería de Software – nombre por completar)	CE02 — Ingeniería de Software (requerimientos, datos, sistema, calidad)

Docente asesor(a) del curso: (*nombre del docente asesor por completar*) **Curso / Sílabo:** (*nombre del curso / sílabo por completar*) **Ciclo académico:** 2026-I (supuesto, a confirmar con la programación académica vigente)

Lugar y fecha: Juliaca, Puno, Perú — 07 de julio de 2026

Nota metodológica y alcance (léase antes de continuar). Este documento se apoya directamente en los entregables precedentes del proyecto: del **Entregable N.º 1** (Diagnóstico Organizacional) toma la caracterización de la organización ilustrativa “**Microred de Salud Altiplano-Puno**”, su bajo nivel de madurez digital en gobierno de TI y ciberseguridad (nivel 1 de 5, sección 1.3.2) y el inventario de sistemas de información existentes; del **Entregable N.º 2** (Business Case) toma el modelo de negocio B2G de 3 fases, el presupuesto de validación de Fase 0 (S/ 3,124) y el riesgo estratégico R5 ya identificado (“brecha de seguridad o incumplimiento de la Ley N.º 29733”), que este documento desarrolla y opera-cionaliza en detalle; del **Entregable N.º 3** (Plan de Gestión) toma el paquete de trabajo 2.3 “Seguridad, identidad y control de acceso” (asignado al Integrante 1, con el entregable “ambiente de autenticación operativo + checklist de seguridad” como criterio de aceptación); y del **Entregable N.º 5** (Requerimientos y Diseño del Sistema) toma íntegramente la arquitectura ya diseñada (backend FastAPI/NestJS, PostgreSQL+PostGIS, Keycloak OIDC/RBAC — ADR-09—, servidor único de Fase 0 — ADR-02, ADR-10—), los seis recursos FHIR del proyecto, los ocho actores del sistema y los requerimientos no funcionales de seguridad ya especificados (RNF-05 a RNF-07, RNF-18, RNF-19;

RF-39, RF-40; RN-02 a RN-11). Este Entregable N.º 2 de la competencia CE032 **no rediseña** esa arquitectura: la toma como dada y construye sobre ella la capa de gobierno, gestión de riesgos y políticas de seguridad de la información que la rúbrica CE0321 exige.

Se mantiene vigente la misma advertencia metodológica de los entregables anteriores: HemoScan Andino **no cuenta todavía con un convenio real** con ninguna microred o posta de salud, ni con un comité de ética constituido, ni con un servidor de producción desplegado. Por ello, este plan de seguridad tiene naturaleza de **planificación previa (pre-despliegue)**: define los controles, políticas y roles que deberán estar operativos **antes** de procesar el primer dato real de un menor de edad en la Fase 0 de validación, no la certificación de un sistema ya operando. Su alcance es además **dual**, y esto se declara explícitamente para evitar ambigüedad: cubre (a) los activos propios de HemoScan Andino como organización emprendedora (código fuente, modelo de inteligencia artificial, dataset propietario, credenciales del equipo fundador) y (b) los activos que existirán en el entorno operativo de la organización cliente ilustrativa “Microred de Salud Altiplano-Puno” una vez desplegado el sistema (servidor de la posta, dispositivos de campo, cuentas del personal de salud), dado que el modelo de negocio B2G implica que la futura HemoScan Andino S.A.C. actuará como **encargada de tratamiento** de datos de salud sobre una infraestructura cuya modalidad exacta de alojamiento (servidor propio del equipo, nube comercial, o servidor físico dentro de la posta) es todavía **[DATO PENDIENTE DE VALIDAR: modalidad de alojamiento definitiva, a acordar contractualmente con la DIRESA/microred en la Fase 1]**. Todo valor numérico o afirmación normativa específica que no pueda derivarse razonablemente de lo ya declarado en el proyecto o de un estándar internacional de referencia pública (ISO/IEC 27001, ISO/IEC 27005, NIST) se marca explícitamente como **[DATO PENDIENTE DE VALIDAR]**, en lugar de presentarse como un hecho verificado.

Resumen Ejecutivo

HemoScan Andino procesa, por definición de su propio modelo de negocio, uno de los tipos de datos más sensibles que contempla el ordenamiento jurídico peruano: datos de salud de menores de edad, agravados por la dimensión geográfica (comunidades altoandinas dispersas), la dimensión tecnológica (inteligencia artificial embebida clasificada como de alto riesgo por el Decreto Supremo N.º 115-2025-PCM) y la dimensión organizacional (una microred cuyo nivel de madurez en gobierno de TI y ciberseguridad fue diagnosticado, en el Entregable N.º 1, en el nivel más bajo de una escala de cinco). Este documento desarrolla la **Planificación de Seguridad** exigida por la competencia CE032 — Gestión de la Seguridad de la Información, adoptando como marco metodológico central la familia de normas **ISO/IEC 27001:2022** (requisitos de un sistema de gestión de seguridad de la información), **ISO/IEC 27002:2022** (catálogo de controles) e **ISO/IEC 27005:2022** (gestión de riesgos de seguridad de la información), complementada con el proceso de evaluación de riesgos de **NIST SP 800-30 Rev. 1** y las seis funciones del **NIST Cybersecurity Framework (CSF) 2.0** (Gobernar, Identificar, Proteger, Detectar, Responder, Recuperar), en estricta observancia del DS 115-2025-PCM y de la Ley N.º 29733 de Protección de Datos Personales.

La **Sección 1** identifica y clasifica veintiocho activos críticos organizados en siete categorías (datos e información, credenciales y secretos, software, hardware, servicios, personas e intangibles), evaluados según el triángulo de confidencialidad, integridad y disponibilidad (CID), con

propietario y custodio explícitos para cada uno. Se confirma que los activos de mayor criticidad global son, en este orden, los datos clínicos identificables de menores de edad, el servidor único que aloja el backend y la base de datos (punto único de falla ya reconocido en el Entregable N.º 5), y las credenciales/secretos de integración del backend.

La **Sección 2** aplica la metodología ISO 27005/NIST mediante una matriz semicuantitativa de diecinueve riesgos de seguridad de la información (identificados con el prefijo RS-01 a RS-19), cada uno con su amenaza, vulnerabilidad explotable, probabilidad e impacto en escala 1-5, puntaje de riesgo (probabilidad $\times$ impacto, rango 1-25) y nivel cualitativo resultante (Bajo, Moderado, Alto, Crítico). Cuatro riesgos alcanzan nivel Crítico: el acceso no autorizado por credenciales no revocadas ante la alta rotación del personal (régimen SERUMS), la pérdida o robo de un nodo/smartphone de campo con datos sin cifrar, la exposición accidental de secretos de configuración en un repositorio de código, y la ingeniería social dirigida al personal de salud. Estos resultados **desarrollan y operacionalizan**, con un método formal, el riesgo estratégico R5 ya declarado de forma cualitativa en el Business Case (Entregable N.º 2).

La **Sección 3** define once políticas de seguridad detalladas y aplicables —control de accesos, protección de datos de menores, gestión criptográfica, dispositivos de campo y movilidad, copias de seguridad y continuidad, gestión de incidentes, desarrollo seguro, uso aceptable y concientización, gobernanza de inteligencia artificial, gestión de terceros, y un cierre de ética profesional alineado al Código de Ética y Conducta Profesional de la ACM—, cada una con lineamientos numerados, parámetros técnicos concretos (por ejemplo, cifrado TLS 1.2 o superior y AES-256 en reposo, autenticación multifactor para roles clínicos y administrativos, respaldo diario con prueba trimestral de restauración) y su control equivalente del Anexo A de ISO/IEC 27001:2022.

La **Sección 4** propone una estructura de gobierno de seguridad proporcional al tamaño real del equipo (tres integrantes en Fase 0), con una matriz RACI de doce procesos de seguridad que distingue las responsabilidades internas del equipo HemoScan Andino de las responsabilidades que, en un despliegue real, recaerán sobre el administrador del sistema de la microred y sobre el Comité de Ética/DIRESA como titular del banco de datos de salud, y plantea como hoja de ruta la creación de un rol formal de Oficial de Seguridad de la Información y de un Oficial de Protección de Datos una vez constituida HemoScan Andino S.A.C.

El cuerpo evaluable de este documento (Secciones 1 a 4, más los Anexos A, B y D) se ajusta al rango de 10-15 páginas indicado por la plantilla del entregable, y cierra con la matriz de riesgos completa con tratamiento y riesgo residual estimado (**Anexo A**), las referencias normativas y de estándares (**Anexo B**) y el checklist de seguridad que opera el criterio de aceptación del paquete EDT 2.3 del Plan de Gestión (**Anexo D**), este último ampliado con la verificación de la validación legal pendiente de las Políticas 3.2 y 3.6 (Sección 3.12). El glosario de términos y el índice de diagramas —material útil pero no exigido por la plantilla— se reclasifican como **material complementario de referencia**, ubicado después del cierre formal del cuerpo evaluable. Al final del documento se incluye, también fuera del cuerpo evaluable, una **nota interna de cobertura frente a la rúbrica** (no una autocalificación, tarea que corresponde exclusivamente al docente/evaluador) que documenta honestamente, como limitaciones centrales aún abiertas, la ausencia de una evaluación de riesgos validada con datos reales de incidentes, un pentest técnico ejecutado, un comité de ética constituido, y la validación legal peruana específica de los parámetros pendientes de las Políticas 3.2 y 3.6, insumos que solo estarán disponibles una vez formalizado un convenio institucional real.

1. Identificación de Activos Críticos

1.1 Metodología de identificación y clasificación

La identificación de activos sigue el enfoque de **ISO/IEC 27001:2022, control A.5.9 (Inventario de información y otros activos asociados)**: todo activo que soporte el proceso de tamizaje de anemia infantil —ya sea información, software, hardware, un servicio contratado o una persona con acceso privilegiado— se registra con un identificador único (AC-01 a AC-28), su categoría, un **propietario** (quien decide su uso y clasificación) y un **custodio** (quien lo opera y protege técnicamente en el día a día), siguiendo la separación de responsabilidades que exige la norma.

Cada activo se valora según el triángulo clásico de seguridad de la información —**Confidencialidad (C), Integridad (I) y Disponibilidad (D)**— en una escala ordinal de tres niveles (Alta / Media / Baja), y se deriva una **críticidad global** igual al valor máximo alcanzado entre C, I y D, ajustada cualitativamente cuando el activo involucra datos de menores de edad o constituye un punto único de falla ya reconocido en la arquitectura (Entregable N.º 5, ADR-02 y ADR-10), en cuyo caso la criticidad global se fija en Alta con independencia del promedio matemático. Esta regla de ajuste es una decisión metodológica propia del equipo, no una prescripción literal de la norma, y se declara explícitamente por transparencia.

Nivel	Confidencialidad (C)	Integridad (I)	Disponibilidad (D)
Alta	La divulgación no autorizada vulnera datos de salud de un menor de edad, secretos criptográficos o propiedad intelectual central del producto	La alteración no autorizada puede inducir un diagnóstico o tratamiento erróneo, o falsificar un registro de auditoría	La indisponibilidad detiene el tamizaje en campo o dejar sin operar el único servidor de la posta
Media	La divulgación afecta información operativa u organizacional sin exponer datos clínicos individuales de un menor	La alteración degrada la calidad del servicio o de un reporte, sin efecto clínico directo	La indisponibilidad es tolerable por horas gracias al diseño offline-first (RNF-03)
Baja	La divulgación tiene impacto marginal o es información ya pública/agregada	La alteración es detectable y corregible sin efecto sobre terceros	La indisponibilidad no afecta la operación crítica del tamizaje

1.2 Inventario de activos críticos

Datos e información

ID	Activo	Propietario	Custodio	C	I	D	Criticidad global
AC-01	Datos clínicos identificables de menores de edad (recursos FHIR <i>Patient y Observation</i>)	Titular del banco de datos de salud (micro-red/DIRESAte 3) futuro contrato)	Backend de interoperabilidad (Integrante 3)	Alta	Alta	Media	Alta
AC-02	Consentimientos informados digitales (recurso FHIR <i>Consent</i>)	Cuidador/a (titular del derecho)	Backend / App móvil	Alta	Alta	Media	Alta
AC-03	Trazas de auditoría y procedencia (recursos FHIR <i>Provenance, AuditEvent</i>)	HemoScan Andino (equipo)	Servicio de Auditoría (backend)	Media	Alta	Media	Alta
AC-04	Dataset propietario de entrenamiento (imágenes de conjuntiva, espectros AS7341, señales PPG MAX30102 y etiquetas de referencia Hemo-Cue/ferritina/PCR)	HemoScan Andino (equipo)	Integrante 3 / repositorio de datos de entrenamiento	Alta	Alta	Media	Alta
AC-05	Modelo de inferencia de IA entrenado (pesos ONNX/TFLite y su versionado)	HemoScan Andino (equipo)	Integrante 3	Media	Alta	Media	Alta

ID	Activo	Propietario	Custodio	C	I	D	Criticidad global
AC-06	Tabla/parámetros de corrección de hemoglobina por altitud y umbrales clínicos versionados (RN-02)	HemoScan Andino (equipo), validado por Personal médico	Backend (Configuración Clínica)	Media	Alta	Media	Alta
AC-07	Motor de reglas de consejería nutricional (alineado a NTS 213-MINSA/DGIESP-2024)	HemoScan Andino (equipo)	Integrante 3	Baja	Alta	Media	Media
AC-08	Copias de respaldo (<i>backups</i>) de la base de datos clínica y geoespacial	HemoScan Andino (equipo)	Integrante 1	Alta	Alta	Alta	Alta

Credenciales y secretos

ID	Activo	Propietario	Custodio	C	I	D	Criticidad global
AC-09	Credenciales del backend (claves de base de datos, <i>client secrets</i> de Keycloak, tokens de integración HIS-MINSA/Padrón Nominal/SIGA)	HemoScan Andino (equipo)	Integrante 1	Alta	Alta	Media	Alta

ID	Activo	Propietario	Custodio	C	I	D	Criticidad global
AC-10	Certificados TLS/SSL del backend FHIR y de la plataforma web	HemoScan Andino (equipo)	Integrante 1	Media	Alta	Alta	Alta
AC-11	Credenciales de acceso del personal de salud y agentes comunitarios (cuentas Keycloak, roles CRED/médico/farmacia)	Microred (futuro), HemoScan Andino (Fase 0)	Administrado del sistema	Alta	Media	Media	Alta
AC-12	Credenciales administrativas (super-usuario Keycloak, acceso raíz al servidor)	HemoScan Andino (equipo)	Integrante 1	Alta	Alta	Media	Alta

Software

ID	Activo	Propietario	Custodio	C	I	D	Criticidad global
AC-13	Código fuente de la app móvil (Flutter/PWA)	HemoScan Andino (equipo)	Integrante 3	Media	Alta	Media	Alta
AC-14	Código fuente del backend de interoperabilidad (FastAPI/NestJS)	HemoScan Andino (equipo)	Integrante 3	Media	Alta	Media	Alta
AC-15	Firmware del nodo (C/C++, ESP32-S3)	HemoScan Andino (equipo)	Integrante 1	Baja	Alta	Media	Media

ID	Activo	Propietario	Custodio	C	I	D	Criticidad global
AC-16	Sistema de identidad Keycloak (configuración de <i>realm</i> , políticas OIDC/RBAC —	HemoScan Andino (equipo)	Integrante 1	Media	Alta	Alta	Alta
AC-17	ADR-09) Plataforma web de analítica geoespacial (React/TypeScript)	HemoScan Andino (equipo)	Integrante 3	Baja	Media	Media	Media

Hardware

ID	Activo	Propietario	Custodio	C	I	D	Criticidad global
AC-18	Nodos de hardware HemoScan Andino en campo (ESP32-S3 + AS7341 + MAX30102 + LED)	HemoScan Andino (equipo)	Integrante 1 / Personal CRED en uso	Media	Media	Alta	Alta
AC-19	Smartphones del personal de campo (Personal CRED/médico)	Microred (futuro) / personal (Fase 0)	Personal CRED / Personal médico	Alta	Media	Alta	Alta
AC-20	Servidor/nube único de la posta (backend + BD + Keycloak — ADR-02, ADR-10)	HemoScan Andino (equipo)	Integrante 1	Alta	Alta	Alta	Alta

ID	Activo	Propietario	Custodio	C	I	D	Criticidad global
AC-21	Equipo de referencia HemoCue usado en la validación clínica de Fase 0	Microred ilustrativa (préstamo/convenio)	Personal médico / Personal CRED	Baja	Alta	Media	Media

Servicios

ID	Activo	Propietario	Custodio	C	I	D	Criticidad global
AC-22	Integración con sistemas externos (HIS-MINSA, Padrón Nominal, SIGA)	MINSA / MEF-RENIEC (dato externo)	Integrante 3 (conector)	Alta	Alta	Media	Alta
AC-23	Servicio de hosting/nube contratado	HemoScan Andino (equipo)	Integrante 1	Media	Media	Alta	Alta
AC-24	Servicio de notificaciones push/SMS a cuidadores	HemoScan Andino (equipo)	Integrante 3	Media	Baja	Media	Media

Personas

ID	Activo	Propietario	Custodio	C	I	D	Criticidad global
AC-25	Personal de salud (CRED, médico, farmacia) como custodio operativo de datos y dispositivos	Microred (futuro)	Jefatura de microred	Alta	Media	Alta	Alta

ID	Activo	Propietario	Custodio	C	I	D	Criticidad global
AC-26	Equipo HemoScan Andino (los 3 integrantes) como custodio de código, infraestructura y llaves	HemoScan Andino (equipo)	Los 3 integrantes	Alta	Alta	Alta	Alta

Intangibles

ID	Activo	Propietario	Custodio	C	I	D	Criticidad global
AC-27	Reputación institucional y confianza pública (“licencia social para operar”)	HemoScan Andino (equipo)	Equipo / futura S.A.C.	Media	Alta	Baja	Alta
AC-28	Propiedad intelectual del algoritmo de fusión multisensor y de autocalibración por altitud (potencial modelo de utilidad/patente, ya anotado como riesgo competitivo R10 en el Business Case)	HemoScan Andino (equipo)	Integrante 3	Alta	Media	Baja	Alta

1.3 Síntesis de activos de máxima criticidad

Del inventario de veintiocho activos, veintitrés (el 82 %) alcanzan criticidad global **Alta**, cinco se clasifican como Media y ninguno como Baja, lo que confirma cuantitativamente la observación cualitativa ya hecha en el Entregable N.º 1: una organización con datos de máxima sensibilidad (salud de menores) y una arquitectura deliberadamente concentrada en un único servidor de bajo costo (ADR-02, ADR-10) no tiene margen para tratar la seguridad de la información como un asunto secundario. Cinco activos merecen mención explícita como prioridad absoluta de protección, por concentrar simultáneamente alta confidencialidad, alta integridad y relevancia legal directa: **AC-01** (datos clínicos de menores), **AC-02** (consentimientos, precondition legal obligatoria de cualquier captura por RN-04), **AC-09** y **AC-12** (credenciales/secreto, cuya exposición compromete transitivamente a todos los demás activos del backend) y **AC-20** (el servidor único, cuya pérdida de disponibilidad detiene la operación completa del backend, Keycloak y la base de datos a la vez). Esta síntesis es la que orienta la priorización de riesgos de la Sección 2 y el diseño de controles de la Sección 3. Como mejora no obligatoria para esta etapa de planificación pre-despliegue, se recomienda —una vez desplegado el servidor de producción— contrastar este inventario documental contra un **CMDB** (*Configuration Management Database*) **técnico real**, verificando que cada activo aquí declarado corresponda exactamente a un elemento de configuración operativo y detectando activos no documentados que puedan haberse incorporado durante la implementación.

2. Análisis de Riesgos (ISO 27005 / NIST)

2.1 Metodología

El análisis de riesgos adopta el proceso de **ISO/IEC 27005:2022** —establecimiento del contexto, identificación del riesgo, análisis del riesgo (probabilidad $\times$ consecuencia), evaluación del riesgo frente a criterios de aceptación, y tratamiento del riesgo—, complementado con el modelo de **NIST SP 800-30 Rev. 1**, que descompone cada escenario en una **fuentes de amenaza** (humana deliberada, humana accidental, ambiental o de falla técnica), un **evento de amenaza** que explota una **vulnerabilidad** concreta del activo, produciendo un **impacto adverso**. La siguiente tabla resume la correspondencia entre ambos marcos y las seis funciones del NIST CSF 2.0, usada como verificación cruzada de cobertura:

Fase ISO/IEC 27005:2022	Paso equivalente NIST SP 800-30	Función NIST CSF 2.0 relacionada
Establecimiento del contexto	Preparación de la evaluación	Gobernar (<i>Govern</i>)
Identificación del riesgo	Identificación de fuentes y eventos de amenaza, y de vulnerabilidades	Identificar (<i>Identify</i>)
Análisis y evaluación del riesgo	Determinación de probabilidad e impacto; cálculo del riesgo	Identificar (<i>Identify</i>) / Proteger (<i>Protect</i>)
Tratamiento del riesgo	Comunicación de resultados y priorización de controles	Proteger (<i>Protect</i>), Detectar (<i>Detect</i>)
Monitoreo y revisión	Mantenimiento de la evaluación	Detectar (<i>Detect</i>), Responder (<i>Respond</i>), Recuperar (<i>Recover</i>)

Para el cálculo, se emplea una escala semicuantitativa de **1 a 5** tanto para probabilidad como para impacto, con un puntaje de riesgo igual a **probabilidad $\times$ impacto** (rango 1-25), clasificado en cuatro bandas:

Puntaje ($P \times I$)	Nivel de riesgo	Criterio de tratamiento
16 - 25	Crítico	Tratamiento inmediato; requiere control compensatorio antes de procesar el primer dato real de un menor
11 - 15	Alto	Tratamiento prioritario dentro del paquete EDT 2.3 (Fase 0)
6 - 10	Moderado	Tratamiento planificado dentro del roadmap de Fase 1
1 - 5	Bajo	Aceptar y monitorear; revisar en cada ciclo de revisión del SGSI (sección 4)

Escala de probabilidad: (1) Muy baja — improbable en el horizonte de Fase 0-1; (2) Baja — podría ocurrir de forma excepcional; (3) Media — es razonable que ocurra en algún momento del piloto; (4) Alta — se considera probable dado el contexto ya diagnosticado (madurez digital nivel 1, rotación SERUMS, dispersión geográfica); (5) Muy alta — existen indicios concretos de que ya ocurre de forma análoga (por ejemplo, el uso ya diagnosticado de *shadow IT*).

Escala de impacto: (1) Insignificante; (2) Menor — molestia operativa sin efecto clínico ni legal; (3) Moderado — degradación del servicio sin exposición de datos de menores; (4) Mayor — exposición parcial de datos o indisponibilidad prolongada; (5) Catastrófico — compromiso de datos clínicos de menores de edad, decisión clínica errónea inducida, o incumplimiento grave de la Ley N.º 29733 o del DS 115-2025-PCM.

2.2 Taxonomía de fuentes de amenaza consideradas

Siguiendo la taxonomía de NIST SP 800-30, se consideran cuatro fuentes de amenaza aplicables al contexto de HemoScan Andino: **(a) humana deliberada** (atacante externo, personal interno malicioso, suplantación de identidad); **(b) humana accidental** (error de configuración, extravío de un dispositivo, publicación accidental de un secreto, uso de canales informales por desconocimiento); **(c) ambiental/estructural** (condiciones de campo altoandinas ya diagnosticadas en el Entregable N.º 1: dispersión geográfica, conectividad y electricidad intermitentes, clima extremo); y **(d) falla técnica** (indisponibilidad del servidor único, expiración no gestionada de certificados, defectos de software). Cada riesgo de la matriz siguiente se etiqueta con su fuente de amenaza predominante.

2.3 Matriz de riesgos de seguridad de la información (riesgo inherente)

La matriz siguiente desarrolla, con método formal, el riesgo estratégico **R5** ya identificado cualitativamente en el Business Case (Entregable N.º 2: “brecha de seguridad o incumplimiento de la Ley N.º 29733... Probabilidad Baja, Impacto Crítico, Nivel Alto”) y lo descompone en diecinueve escenarios técnicos específicos y auditables.

ID	Activo(s) (AC-##)	Fuente	Amenaza	Vulnerabilidad explotada	P	I	Riesgo	Nivel
RS-01	AC-01, AC-11	Humana accidental	Acceso indebido a historiales clínicos de menores mediante cuentas de personal saliente no desactivadas a tiempo	Ausencia de proceso formal de baja inmediata de cuentas Keycloak al finalizar el periodo SE-RUMS (alta rotación, Entregable N.º 1)	4	5	20	Crítico
RS-02	AC-01, AC-08, AC-20	Humana deliberada	Exfiltración o filtración masiva de la base de datos clínica por explotación de una vulnerabilidad del backend expuesto a internet	Backend sin <i>hardening</i> , gestión de parches ni <i>firewall</i> de aplicaciones web (WAF); cifrado en reposo aún no verificado en la práctica	3	5	15	Alto

ID	Activo(s) (AC- ##)	Fuente	Amenaza	Vulnerabilidad explota- da	P	I	Riesgo	Nivel
RS-03	AC-20	Falla técnica	Indisponibili- total del sistema por so- brecarga o ataque de dene- gación de servicio al servidor único (backend + BD + Key- cloak, ADR- 02/ADR- 10)	Arquitectura de un único servidor sin redun- dancia ni balanceo de carga	3	4	12	Alto
RS-04	AC-08, AC-20	Falla técnica	Pérdida irreversi- ble de datos clínicos e históri- cos por ausencia o falla de copias de segu- ridad periódicas	No existe todavía una política formal de respaldo ni prueba docu- mentada de restaura- ción	3	5	15	Alto
RS-05	AC-18, AC-19	Ambiental / humana acciden- tal	Pérdida, robo o extravío de un nodo o <i>smartpho- ne</i> de campo con datos clínicos en el búfer <i>offline</i> local	Dispersión geográfi- ca (Entre- gable N.º 1, 1.1.1) y ausencia de cifrado de alma- cena- miento local o de borra- do/bloqueo remoto	4	4	16	Crítico

ID	Activo(s) (AC- ##)	Fuente	Amenaza	Vulnerabilidad explota- da	P	I	Riesgo	Nivel
RS-06	AC-09, AC-14	Humana acciden- tal	Exposición de cre- dencia- les/secretos (claves de BD, <i>client</i> <i>secret</i> de Key- cloak, tokens HIS- MINSA) por pu- blicación acciden- tal en un reposito- rio de código	Falta de gestión de secretos (varia- bles de en- torno/ <i>vault</i>) y de revisión previa a cada <i>com- mit</i> / <i>push</i> , riesgo típico de reposito- rios académi- cos	4	4	16	Crítico
RS-07	AC-06	Humana delibera- da	Alteración no auto- rizada de la tabla de corrección de hemo- globina por altitud o de los umbrales clínicos	Ausencia de control de inte- gridad (fir- ma/hash) y de doble aproba- ción sobre cambios en la configu- ración clínica parame- trizable (RN-02)	2	5	10	Moderado

ID	Activo(s) (AC-##)	Fuente	Amenaza	Vulnerabilidad explotada	P	I	Riesgo	Nivel
RS-08	AC-01, AC-16	Humana deliberada	Suplantación del rol “Personal médico” para ejecutar confirmaciones diagnósticas o prescripciones sin autorización real (<i>bypass</i> de RN-06)	Ausencia de autenticación multifactor para roles clínicos críticos	2	5	10	Moderado
RS-09	AC-10	Falla técnica	Intercepción o degradación de la confiabilidad en tránsito por certificado TLS expirado o mal configurado	Proceso de renovación de certificados no automatizado (costo ya presu- puesto en el Entregable N.º 2, sin procedimiento operativo definido)	3	4	12	Alto

ID	Activo(s) (AC- ##)	Fuente	Amenaza	Vulnerabilidad explota- da	P	I	Riesgo	Nivel
RS-10	AC-01	Humana delibera- da / acciden- tal	Reidentificación indirecta de niños o familias a partir de datos “anoni- mizados” del mapa de cobertura/riesgo si la celda H3 es demasiado fina en zonas de muy baja densidad	Falta de un umbral mínimo de agregación (k -anonimato) antes de exponer una celda H3 en la plataforma web (brecha de implementación de RN-08)	3	4	12	Alto
RS-11	AC-15, AC-18	Humana delibera- da	Manipulación del firmware del nodo mediante carga de firmware no autorizado	Ausencia de actualización OTA firmada criptográficamente y de verificación de integridad del firmware	2	3	6	Moderado
RS-12	AC-18	Humana delibera- da	Interceptación (<i>sniffing</i>) del canal BLE entre el nodo y la app durante la transmisión de señales ópticas crudas	Emparejamiento BLE sin cifrado GATT reforzado ni verificación de vínculo (<i>bonding</i>)	2	3	6	Moderado

ID	Activo(s) (AC- ##)	Fuente	Amenaza	Vulnerabilidad explota- da	P	I	Riesgo	Nivel
RS-13	AC-25	Humana delibera- da	Ingeniería so- cial/ <i>phishing</i> dirigido al personal de salud o al adminis- trador del sistema para obtener creden- ciales	Baja madurez de ciberse- guridad y concién- tización del personal (Entre- gable N.º 1, nivel 1/5 en gobierno de TI y ciberse- guridad)	4	4	16	Crítico
RS-14	AC-01	Humana acciden- tal	Uso de canales no oficiales (mensa- jería instantá- nea informal, <i>shadow</i> <i>IT</i>) para compar- tir informa- ción clínica entre personal de salud	Práctica ya diagnos- ticada en el En- tregable N.º 1 (sección 1.3.1) como canal sin trazabi- lidad institu- cional	4	3	12	Alto

ID	Activo(s) (AC- ##)	Fuente	Amenaza	Vulnerabilidad explota- da	P	I	Riesgo	Nivel
RS-15	AC-04, AC-05	Humana delibera- da	Manipulación del dataset o de las actuali- zaciones del modelo durante el reen- trena- miento federado (<i>data- model poisoning</i>), una vez activado en Fase 1/2 (ADR- 08)	Ausencia de vali- dación de inte- gridad de las actuali- zaciones de pará- metros recibidas de cada posta	2	4	8	Moderado
RS-16	AC-26	Estructural / organi- zacional	Concentración del cono- cimiento técnico y de accesos privile- giados en un solo in- tegrante (“ <i>bus factor</i> ”), sin respaldo docu- mentado de configu- raciones críticas	Equipo de 3 personas sin do- cumen- tación de conti- nuidad ni acceso de respaldo (relacio- nado con el riesgo organi- zacional R9 del Business Case)	3	3	9	Moderado

ID	Activo(s) (AC- ##)	Fuente	Amenaza	Vulnerabilidad explota- da	P	I	Riesgo	Nivel
RS-17	AC-05, AC-28	Humana acciden- tal	Registro audita- ble incom- pleto de reco- menda- ciones genera- das por el com- ponente de IA, dificul- tando demos- trar cumpli- miento del DS 115- 2025- PCM	Implementación parcial o tardía de RF-40 (registro de toda reco- menda- ción de IA con supervi- sión humana explíci- ta)	3	4	12	Alto
RS-18	AC-21, AC-22	Humana acciden- tal	Ruptura de la cadena de custodia de datos durante la vali- dación cruzada con HemoCue/ PCR de Fase 0	Coexistencia temporal de registro digital (HemoS- can) y registro manual del labo- ratorio de HemoCue/ PCR de Fase 0	3	3	9	Moderado

ID	Activo(s) (AC-##)	Fuente	Amenaza	Vulnerabilidad explotada	P	I	Riesgo	Nivel
RS-19	AC-18	Cadena de suministro	Sustitución o adulteración de componentes electrónicos (AS7341, MAX30102) por un proveedor no autorizado	Proceso de adquisición sin verificación de autenticidad ni proveedor único certificado (riesgo ya anotado como R6 en el Business Case)	2	2	4	Bajo

2.4 Mapa de calor de riesgo inherente (probabilidad × impacto)

	P=1	P=2	P=3	P=4
I=5 Catastrófico	-	RS-07, RS-08	RS-02, RS-04	RS-01
I=4 Mayor	-	RS-15	RS-03, RS-09, RS-10, RS-17	RS-05, RS-06, RS-13
I=3 Moderado	-	RS-11, RS-12	RS-16, RS-18	RS-14
I=2 Menor	-	RS-19	-	-
I=1 Insignificante	-	-	-	-

Leyenda de bandas: celdas con puntaje 16-25 (esquina superior derecha) = Crítico; 11-15 = Alto; 6-10 = Moderado; 1-5 = Bajo (esquina inferior izquierda).

2.5 Priorización y estrategia de tratamiento

De los diecinueve riesgos identificados, **cuatro son de nivel Crítico** (RS-01, RS-05, RS-06, RS-13), **siete de nivel Alto** (RS-02, RS-03, RS-04, RS-09, RS-10, RS-14, RS-17), **siete de nivel Moderado** (RS-07, RS-08, RS-11, RS-12, RS-15, RS-16, RS-18) y **uno de nivel Bajo** (RS-19). Es relevante notar que **ninguno de los cuatro riesgos críticos corresponde a un ataque técnicamente sofisticado**: los cuatro se originan en debilidades de gestión (falta de proceso de baja de cuentas, falta de cifrado de dispositivos de campo, falta de gestión de secretos, falta de concientización del personal), lo que confirma un hallazgo consistente con el diagnóstico digital del Entregable N.º 1 (nivel de madurez 1/5 en gobierno de TI y ciberseguridad): la prioridad de tratamiento de Fase 0 no es adquirir herramientas de seguridad sofisticadas, sino **cerrar brechas de proceso básicas** antes de tocar el primer dato real de un menor. En términos de las cuatro opciones de tratamiento de ISO/IEC 27005 (modificar/mitigar, retener/aceptar, evitar, compartir/transferir), este documento **mitiga** dieciséis de los diecinueve riesgos mediante controles técnicos y de proceso (Sección 3), **transfiere** parcialmente el riesgo de disponibilidad del hosting (RS-03) mediante la elección de un proveedor de nube con SLA propio en Fase 1 —una vez resuelto el **[DATO PENDIENTE DE VALIDAR: SLA objetivo del servidor, ya señalado como pendiente en el Entregable N.º 5, RNF-20]**—, **evita** la activación

prematura del riesgo de envenenamiento de modelo (RS-15) al mantener el aprendizaje federado inactivo hasta Fase 1/2 (decisión ya tomada en ADR-08) y **acepta con monitoreo** el único riesgo de nivel Bajo (RS-19), por su naturaleza de cadena de suministro externa al control directo del equipo. El desarrollo completo del tratamiento y del riesgo residual estimado para cada uno de los diecinueve riesgos se presenta en el **Anexo A**.

3. Políticas de Seguridad

Las siguientes once políticas traducen el análisis de riesgos de la Sección 2 en reglas concretas, aplicables y auditables. Cada política indica su objetivo, sus lineamientos numerados, el o los controles equivalentes del **Anexo A de ISO/IEC 27001:2022** (citados de forma general por tema, dado el carácter público y estandarizado de dicho catálogo) y su vínculo con los requerimientos ya definidos en el Entregable N.º 5. Todas las políticas rigen desde la Fase 0 de validación, no solo desde un eventual despliegue comercial.

3.1 Política de Control de Accesos

Objetivo: garantizar que cada usuario acceda únicamente a la información y funciones estrictamente necesarias para su rol (principio de mínimo privilegio), en cumplimiento de RNF-06 y RF-37.

1. Toda autenticación se realiza exclusivamente a través de Keycloak (OIDC); ninguna aplicación ni servicio de HemoScan Andino almacena contraseñas propias (ADR-09, ya decidido en el Entregable N.º 5).
2. Se definen, como mínimo, los cuatro roles funcionales exigidos por RNF-06 (Personal CRED, Personal médico, Administrador del sistema, Auditor), ampliables a los ocho actores humanos identificados en el Entregable N.º 5, cada uno con permisos explícitamente delimitados y probados antes de la ejecución de campo.
3. Se exige **autenticación multifactor (MFA)** obligatoria para los roles Administrador del sistema, Personal médico y Auditor/Comité de ética, dado que estos roles pueden confirmar diagnósticos, prescribir tratamiento o acceder a trazas de auditoría completas (mitiga RS-08). Para el rol Personal CRED, dado el uso de teléfonos de gama baja/media y la posible intermitencia de señal para MFA por SMS, se exige como mínimo una contraseña robusta (12 caracteres, complejidad) más vínculo de dispositivo (*device binding*), evaluándose MFA por aplicación de autenticación (TOTP) offline como mejora incremental — **[DATO PENDIENTE DE VALIDAR: factibilidad de TOTP offline en los modelos de smartphone finalmente adquiridos]**.
4. Toda cuenta de personal de salud debe darse de baja o suspenderse **el mismo día** en que finaliza su vínculo con la microred (incluyendo el término del periodo SERUMS), mediante un procedimiento formal de notificación de la Jefatura de microred al Administrador del sistema (mitiga directamente RS-01, el riesgo Crítico de mayor puntaje de toda la matriz).
5. Se realiza una **revisión trimestral** de cuentas activas y de sus roles asignados, documentada y firmada por el Administrador del sistema.
6. Toda cuenta se bloquea automáticamente tras 5 intentos fallidos de autenticación consecutivos, con un tiempo de bloqueo mínimo de 15 minutos.
7. Las acciones de “confirmación diagnóstica” y “prescripción” permanecen reservadas de forma exclusiva al rol Personal médico a nivel de backend (no solo de interfaz), conforme RN-06, de modo que ninguna manipulación del cliente móvil pueda otorgar privilegios no autorizados.

Controles ISO/IEC 27001:2022 relacionados: A.5.15 (Control de acceso), A.5.16 (Gestión de

identidad), A.5.17 (Información de autenticación), A.5.18 (Derechos de acceso), A.8.2 (Derechos de acceso privilegiado), A.8.5 (Autenticación segura).

3.2 Política de Protección de Datos Personales y de Salud de Menores de Edad

Objetivo: cumplir la Ley N.º 29733 y sus principios (legalidad, consentimiento, finalidad, proporcionalidad, calidad, seguridad y disposición de recurso), reconociendo la sensibilidad máxima de tratar datos de salud de personas menores de edad.

1. Ninguna captura de señales ópticas se inicia sin un recurso FHIR *Consent* previamente registrado, vigente y verificable (RN-04); el firmante debe acreditar su relación de parentesco o tutela con el menor.
2. Se aplica el principio de **minimización de datos**: solo se recolectan los campos estrictamente necesarios para el tamizaje, la corrección por altitud y la trazabilidad exigida; no se solicitan datos adicionales “por si acaso”.
3. Todo dato expuesto en la plataforma web de analítica geoespacial (mapa de cobertura/riesgo) debe agregarse a un nivel mínimo de k -anonimato por hexágono H3 antes de su publicación, nunca a nivel de individuo identificable (RN-08); se fija como parámetro de partida un mínimo de $k \geq 5$ casos por celda expuesta, sujeto a validación estadística posterior — **[DATO PENDIENTE DE VALIDAR: umbral óptimo de k según la densidad poblacional real de la microred]**.
4. Se reconoce expresamente que, en un despliegue real, el **titular del banco de datos de salud** es la entidad de salud (microred/DIRESA), mientras que HemoScan Andino S.A.C. actúa como **encargada de tratamiento** bajo un acuerdo contractual que deberá especificar finalidad, plazo de conservación y prohibición de uso secundario no autorizado — **[DATO PENDIENTE DE VALIDAR: cláusulas exactas del futuro contrato de encargo de tratamiento]**.
5. Los datos utilizados para analítica poblacional agregada (Sección 2.5 y RN-09 del Entregable N.º 5) se anonimizan de forma irreversible antes de cualquier uso secundario (planificación regional, publicaciones académicas).
6. Se reconoce a los cuidadores el ejercicio de los derechos de acceso, rectificación, cancelación y oposición (derechos ARCO) sobre los datos de sus hijos, mediante un procedimiento a definir con la Jefatura de microred — **[DATO PENDIENTE DE VALIDAR: procedimiento operativo exacto y plazo de respuesta, a definir en coordinación con la Autoridad Nacional de Protección de Datos Personales]**.
7. El plazo de conservación de los datos clínicos se alinea al que exija la normativa de historias clínicas del sector salud peruano — **[DATO PENDIENTE DE VALIDAR: plazo legal exacto de conservación]** —; mientras tanto, se adopta como valor operativo provisional un mínimo de 15 años desde la última atención, revisable.
8. Toda solicitud de acceso a datos clínicos de un menor por un rol de auditoría, incluyendo accesos de solo lectura, se registra sin excepción en un recurso *AuditEvent* (RN-11).

Controles ISO/IEC 27001:2022 relacionados: A.5.34 (Privacidad y protección de datos personales), A.5.12 (Clasificación de la información), A.5.33 (Protección de registros), A.8.10 (Eliminación de información).

3.3 Política de Gestión Criptográfica

Objetivo: proteger la confidencialidad e integridad de los datos en tránsito y en reposo (RNF-05, RF-39), y eliminar la exposición de secretos identificada como riesgo Crítico (RS-06).

1. Todo tráfico entre la app móvil, la plataforma web y el backend se cifra con **TLS 1.2 como mínimo**, con preferencia por TLS 1.3 cuando el hardware de referencia lo soporte.
2. Los datos en reposo en la base de datos PostgreSQL/PostGIS se cifran a nivel de disco/columna sensible con **AES-256** o algoritmo de fortaleza equivalente.
3. Ningún secreto (claves de base de datos, *client secrets* de Keycloak, tokens de integración con HIS-MINSA/Padrón Nominal/SIGA) se almacena en texto plano dentro del código fuente ni se sube a un repositorio de control de versiones; se gestionan mediante variables de entorno o un gestor de secretos dedicado, con revisión automatizada previa a cada *commit* (mitiga directamente RS-06).
4. Los certificados TLS se renuevan mediante un procedimiento automatizado (por ejemplo, renovación programada con al menos 30 días de anticipación al vencimiento), eliminando la dependencia de un recordatorio manual (mitiga RS-09); el costo de esta renovación ya fue presupuestado como partida de mantenimiento en el Entregable N.º 2.
5. Las llaves criptográficas y los certificados raíz se resguardan bajo custodia exclusiva del Integrante 1 (Infraestructura Tecnológica), con una copia de respaldo cifrada y accesible por un segundo integrante designado, para mitigar el riesgo de “*bus factor*” (RS-16).
6. El firmware del nodo únicamente admite actualizaciones *over-the-air* firmadas criptográficamente, rechazando cualquier imagen de firmware no verificada (mitiga RS-11).

Controles ISO/IEC 27001:2022 relacionados: A.8.24 (Uso de criptografía), A.8.9 (Gestión de la configuración), A.8.12 (Prevención de fuga de datos).

3.4 Política de Seguridad de Dispositivos de Campo y Movilidad

Objetivo: proteger los nodos de hardware y los *smartphones* de campo frente a pérdida, robo o manipulación, dado el contexto de dispersión geográfica ya diagnosticado (Entregable N.º 1) y el riesgo Crítico RS-05.

1. Todo *smartphone* de campo activa cifrado de almacenamiento a nivel de sistema operativo y bloqueo de pantalla obligatorio (PIN/biometría) antes de instalar la app HemoScan Andino.
2. El búfer de sincronización *offline* (cola de *outbox*, ADR-01) se cifra en el almacenamiento local del dispositivo, de modo que la pérdida física del equipo no exponga datos clínicos en texto plano.
3. Se mantiene un inventario físico actualizado de los nodos y *smartphones* asignados por establecimiento, con responsable nombrado (vínculo directo con el inventario de activos AC-18/AC-19 de la Sección 1).
4. Ante la pérdida o robo reportado de un dispositivo, el Administrador del sistema revoca de inmediato las credenciales asociadas y, si la plataforma móvil lo permite, ejecuta borrado remoto del contenido de la app.
5. Los nodos de hardware no se dejan sin supervisión en zonas de acceso público durante las jornadas de campo; su transporte sigue el protocolo ya definido por el paquete EDT 2.5 (Soporte de infraestructura en campo) del Plan de Gestión.
6. Se prohíbe expresamente el uso de dispositivos personales no inventariados (BYOD no controlado) para capturar, almacenar o transmitir datos clínicos de pacientes.

Controles ISO/IEC 27001:2022 relacionados: A.7.9 (Seguridad de los activos fuera de las instalaciones), A.8.1 (Dispositivos *endpoint* de usuario).

3.5 Política de Copias de Seguridad y Continuidad Operativa

Objetivo: garantizar la disponibilidad y recuperabilidad de los datos clínicos ante la falla del servidor único (AC-20), mitigando el riesgo Alto RS-04.

1. Se ejecuta una copia de seguridad **incremental diaria** y una copia **completa semanal** de la base de datos PostgreSQL/PostGIS y de la configuración de Keycloak.
2. Las copias se retienen en una ventana móvil de 90 días, más un respaldo mensual conservado durante 12 meses, almacenado en una ubicación lógicamente separada del servidor de producción.
3. Se ejecuta una **prueba de restauración trimestral** documentada, verificando que la copia es efectivamente utilizable y no solo generada.
4. Se define un objetivo de tiempo de recuperación (**RTO $\leq$ 24 horas**) y un objetivo de punto de recuperación (**RPO $\leq$ 24 horas**) como metas propuestas por este documento para la Fase 0, en ausencia de un SLA contractual definido (RNF-20 del Entregable N.º 5 ya señala esta cifra como pendiente de validar con el proveedor final).
5. Se documenta un plan mínimo de continuidad operativa que reconoce explícitamente la limitación arquitectónica de un único servidor (ADR-02/ADR-10): ante una falla mayor, el modo *offline-first* del cliente móvil (RNF-03, hasta 72 horas de autonomía) actúa como mitigación temporal mientras se restaura el servicio, evitando la pérdida de capturas ya realizadas en campo.

Controles ISO/IEC 27001:2022 relacionados: A.8.13 (Copias de seguridad de la información), A.5.30 (Preparación de las TIC para la continuidad del negocio), A.5.29 (Seguridad de la información durante la interrupción).

3.6 Política de Gestión de Incidentes de Seguridad

Objetivo: detectar, contener, comunicar y aprender de cualquier incidente de seguridad, con especial atención a brechas que involucren datos de menores de edad.

1. Todo incidente se clasifica en cuatro niveles de severidad —Crítico, Alto, Moderado, Bajo— usando la misma escala de la Sección 2, y se registra en una bitácora de incidentes desde su detección.
2. Un incidente que exponga o pueda haber expuesto datos clínicos de un menor de edad se escala internamente al Integrante 2 (responsable de cumplimiento) en un plazo objetivo de **24 horas** desde su detección.
3. Se evalúa, dentro de un plazo objetivo interno de **72 horas** desde la detección, si el incidente amerita notificación a la Autoridad Nacional de Protección de Datos Personales y a los cuidadores afectados; se aclara expresamente que este plazo de 72 horas es un **objetivo interno de buena práctica propuesto por este documento**, inspirado en estándares internacionales comparables, y no una cifra confirmada como plazo legal peruano exigido — **[DATO PENDIENTE DE VALIDAR: plazo legal exacto de notificación de brechas bajo la Ley N.º 29733 y su Reglamento]**.
4. Todo incidente cerrado genera una revisión de causa raíz y una actualización correspondiente de la matriz de riesgos de la Sección 2, cerrando el ciclo de mejora continua exigido por un sistema de gestión de seguridad de la información.
5. El uso de canales informales (mensajería instantánea personal) para reportar un incidente que involucre datos de pacientes queda expresamente prohibido, en coherencia con la Política 3.8.

Controles ISO/IEC 27001:2022 relacionados: A.5.24 (Planificación y preparación de la gestión de incidentes), A.5.25 (Evaluación y decisión sobre eventos de seguridad), A.5.26 (Respuesta a incidentes), A.5.27 (Aprendizaje de los incidentes), A.6.8 (Reporte de eventos de seguridad de

la información).

3.7 Política de Desarrollo Seguro (Secure SDLC)

Objetivo: incorporar la seguridad desde el diseño (“*security by design*”) en el ciclo de vida de desarrollo de la app móvil, el backend y el firmware.

1. Todo cambio de código pasa por revisión de al menos un segundo integrante antes de integrarse a la rama principal (*code review* obligatorio); el repositorio se configura además con protección de rama principal y con un mecanismo automatizado de detección de secretos expuestos (mitiga en parte el “*bus factor*” RS-16 y refuerza estructuralmente la mitigación de RS-06).
2. Las dependencias de terceros (bibliotecas de Flutter, paquetes Python/Node del backend) se revisan periódicamente contra vulnerabilidades conocidas (CVE) antes de cada incremento de *sprint*, y se mantienen ambientes separados de desarrollo, pruebas y producción, usando en desarrollo y pruebas exclusivamente datos sintéticos o anonimizados —nunca datos clínicos reales—.
3. Ninguna funcionalidad que module reglas de negocio críticas (RN-01 a RN-12) se despliega a producción sin evidencia de prueba funcional y de seguridad, coherente con el paquete EDT 4.7 (Aseguramiento de la calidad) del Plan de Gestión.

Controles ISO/IEC 27001:2022 relacionados: A.8.25 (Ciclo de vida de desarrollo seguro), A.8.28 (Codificación segura), A.8.29 (Pruebas de seguridad en desarrollo y aceptación).

3.8 Política de Uso Aceptable y Concientización en Seguridad

Objetivo: elevar la madurez de ciberseguridad del personal de salud, hoy diagnosticada en el nivel más bajo de la escala (Entregable N.º 1, sección 1.3.2), y mitigar el riesgo Crítico RS-13 (ingeniería social).

1. Todo integrante del equipo y todo miembro del personal de salud que use el sistema recibe una capacitación mínima de conscientización en seguridad (reconocimiento de *phishing*, gestión de contraseñas, manejo adecuado de dispositivos) antes de operar el sistema con datos reales, aprovechando la misma jornada de preparación logística y de campo ya prevista en el paquete EDT 3.6 del Plan de Gestión (Entregable N.º 3) y la partida presupuestal de “materiales de gestión, consejería nutricional impresa y capacitación” ya definida en el Business Case (Entregable N.º 2).
2. Se prohíbe expresamente el uso de mensajería instantánea personal no oficial (*shadow IT*) para compartir cualquier dato identificable de un paciente, atacando directamente la práctica ya diagnosticada en el Entregable N.º 1 y el riesgo RS-14 de esta matriz.
3. Se prohíbe compartir credenciales de acceso entre distintos usuarios, incluso entre compañeros del mismo establecimiento en situaciones de aparente urgencia operativa.
4. Todo usuario debe reportar de inmediato cualquier sospecha de correo, mensaje o llamada de *phishing* dirigidos a sus credenciales del sistema, sin sanción por el solo hecho de reportar (cultura de reporte no punitiva).
5. El lenguaje de toda comunicación de seguridad dirigida al personal de campo debe ser simple y no alarmista, en coherencia con RNF-14 ya definido en el Entregable N.º 5, y contemplar la pertinencia intercultural (quechua/aymara) cuando sea aplicable.

Controles ISO/IEC 27001:2022 relacionados: A.6.3 (Concientización, educación y capacitación en seguridad de la información), A.6.8 (Reporte de eventos de seguridad).

3.9 Política de Gobernanza de Inteligencia Artificial y Trazabilidad

Objetivo: dar cumplimiento operativo al DS 115-2025-PCM, que clasifica a la salud como sector de alto riesgo para sistemas de IA y exige supervisión humana significativa y trazabilidad auditable.

1. Ninguna recomendación, alerta o clasificación de severidad generada por el modelo de inferencia se ejecuta como decisión autónoma; toda confirmación diagnóstica y prescripción requiere una acción explícita de un profesional de salud humano autenticado (RN-01, RN-10, ya definidos en el Entregable N.º 5).
2. Toda inferencia del modelo, junto con su versión de modelo y de firmware, se registra de forma auditable (RF-40, RNF-18), cerrando la brecha identificada en el riesgo RS-17 de esta matriz.
3. Todo cambio en la tabla de corrección por altitud o en los umbrales clínicos se versiona y queda trazable a las determinaciones históricas a las que se aplicó cada versión (RN-02, CA-10 del Entregable N.º 5), con doble validación técnica (Integrante 3) y clínica (Personal médico referente).
4. El reentrenamiento federado (Flower), cuando se active en Fase 1/2 (ADR-08), transfiere exclusivamente actualizaciones de parámetros del modelo, nunca datos crudos de pacientes fuera del nodo/posta de origen (RN-09), y valida la integridad de cada actualización recibida antes de incorporarla (mitigación de RS-15).
5. Se mantiene una bitácora de gobernanza de IA disponible para consulta del rol Auditor/Comité de ética (CU-10 del Entregable N.º 5), documentando qué decisiones fueron asistidas por IA y cuál fue la acción humana de supervisión correspondiente.

Controles ISO/IEC 27001:2022 relacionados: A.5.31 (Requisitos legales, estatutarios, regulatorios y contractuales), A.8.16 (Actividades de monitoreo); referencia normativa directa: DS 115-2025-PCM.

3.10 Política de Gestión de Terceros y Cadena de Suministro

Objetivo: extender el control de seguridad a los sistemas externos (HIS-MINSA, Padrón Nominal, SIGA) y a los proveedores de componentes de hardware.

1. Toda integración con un sistema externo, así como cualquier tercero con acceso a datos clínicos o a infraestructura de HemoScan Andino (por ejemplo, un proveedor de hosting en Fase 1), se formaliza mediante un acuerdo o protocolo técnico que especifique el alcance exacto de los datos intercambiados —minimizado a lo estrictamente necesario para la interoperabilidad FHIR— y un compromiso de confidencialidad y cumplimiento mínimo equivalente a las políticas de este documento.
2. Los proveedores de componentes electrónicos (AS7341, MAX30102, ESP32-S3) se seleccionan preferentemente de canales oficiales o distribuidores autorizados, con verificación básica de autenticidad al recibir cada lote, para mitigar el riesgo Bajo RS-19 y el riesgo de cadena de suministro R6 ya anotado en el Business Case.

Controles ISO/IEC 27001:2022 relacionados: A.5.19, A.5.20, A.5.21, A.5.22 (Seguridad de la información en las relaciones con proveedores y en la cadena de suministro de TIC).

3.11 Ética profesional (Código de Ética y Conducta Profesional de la ACM) y responsabilidad social

Esta planificación de seguridad no se concibe únicamente como un ejercicio de cumplimiento normativo, sino como una responsabilidad ética directa del equipo, en línea con el **Código de Ética y Conducta Profesional de la ACM (2018)**. En particular, el principio 1.2 (Evitar

el daño) exige anticipar que un fallo de seguridad en este sistema no es un incidente abstracto de TI, sino uno que puede afectar directamente a un niño o niña y a la confianza de su familia en el sistema de salud; el principio **1.6 (Respetar la privacidad)** y **1.7 (Honrar la confidencialidad)** sustentan directamente la Política 3.2; el principio **2.5 (Ofrecer evaluaciones exhaustivas de los sistemas informáticos y sus impactos, incluido el análisis de riesgos posibles)** es, en esencia, el mandato ético detrás de la Sección 2 de este mismo documento; el principio **2.9 (Diseñar e implementar sistemas robusta y usablemente seguros)** exige que los controles de las políticas anteriores no sean tan onerosos que el personal de salud —ya sobrecargado, según el Entregable N.º 1— termine evadiéndolos por impracticabilidad, razón por la cual varias políticas (3.1, 3.8) equilibran deliberadamente rigor y usabilidad; y el principio **3.7 (Reconocer y cuidar especialmente los sistemas que se integran a la infraestructura de la sociedad)** es directamente aplicable a un sistema que aspira a integrarse en la infraestructura pública de salud regional. Esta sección cierra el conjunto de políticas reconociendo que la seguridad de la información en HemoScan Andino no es solo un requisito de la competencia CE032, sino una condición ética de legitimidad para operar sobre datos de menores de edad en un contexto de alta vulnerabilidad social.

3.12 Precondición legal previa a la operación con datos reales (síntesis de validaciones pendientes de las Políticas 3.2 y 3.6)

Las Políticas 3.2 (Protección de Datos Personales y de Salud de Menores de Edad) y 3.6 (Gestión de Incidentes de Seguridad) están técnicamente completas y fundamentadas, pero dependen de **tres parámetros legales peruanos aún no confirmados con cita normativa exacta**, cada uno ya marcado en su lugar de origen como **[DATO PENDIENTE DE VALIDAR]**. Esta subsección los consolida en un único punto de control, a modo de precondición explícita: **ninguno de los tres debe permanecer como valor provisional una vez que HemoScan Andino procese el primer dato real de un menor de edad** (inicio efectivo de Fase 0 con convenio institucional vigente).

N.º	Parámetro pendiente	Valor provisional usado en este documento	Política que lo referencia	Fuente de validación requerida
1	Plazo legal de notificación de brechas de seguridad	72 horas (objetivo interno de buena práctica, no confirmado como plazo legal peruano)	3.6, regla 3	Ley N.º 29733 y su Reglamento; asesoría legal específica en protección de datos
2	Plazo legal de conservación de historias clínicas del sector salud peruano	15 años desde la última atención (valor operativo provisional, revisable)	3.2, regla 7	Normativa sectorial de historias clínicas del MINSA/sector salud peruano
3	Cláusulas exactas del contrato de encargo de tratamiento (finalidad, plazo, prohibición de uso secundario)	No definidas; dependen de la contraparte real	3.2, regla 4	Convenio institucional a suscribir con la micro-red/DIRESA en Fase 1, con revisión legal

Corrección aplicada: ninguno de estos tres valores se reemplaza en este documento por una cifra definitiva, precisamente porque no existe todavía evidencia normativa ni contractual que la

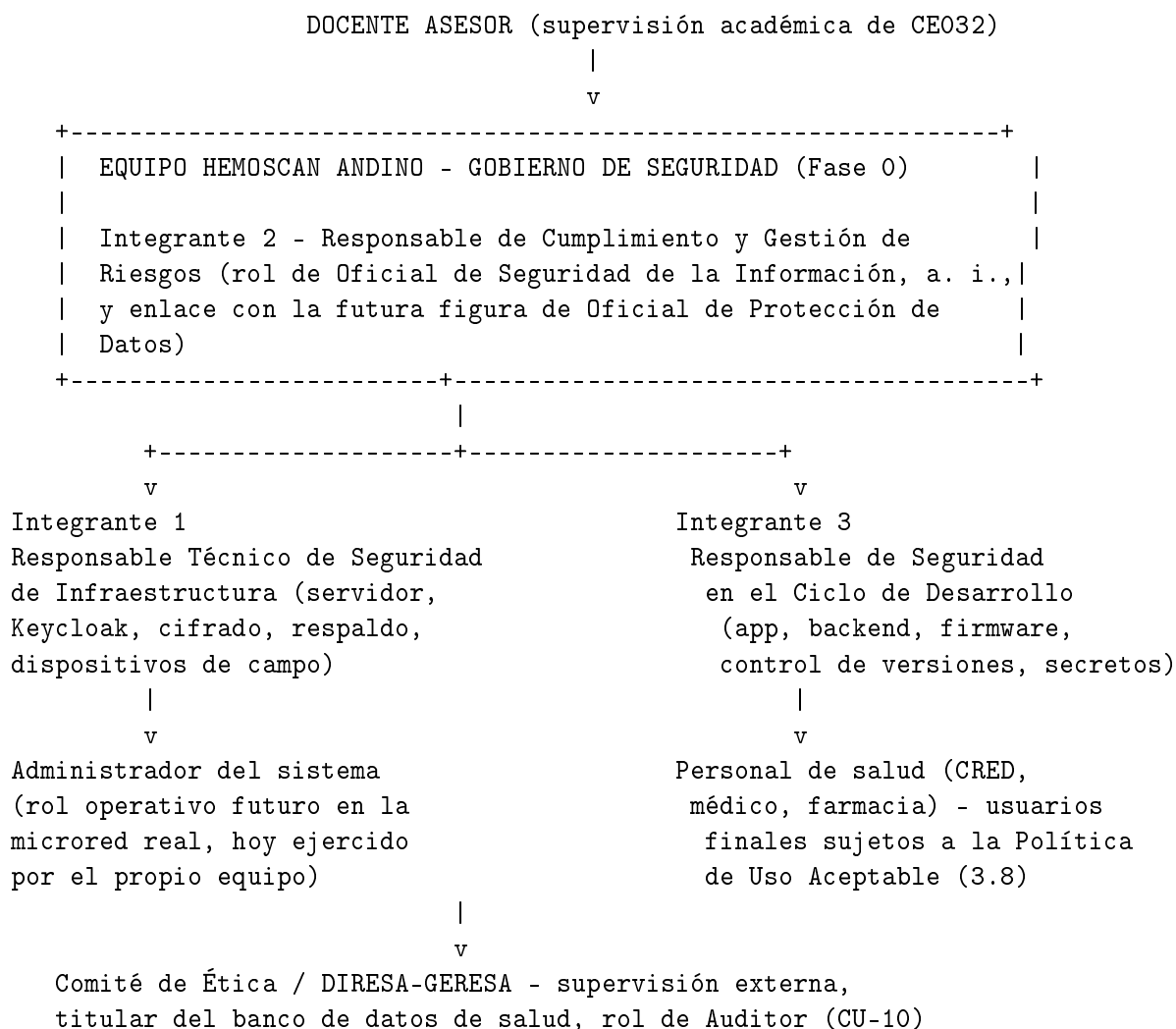
respalde; inventar un número para “cerrar” la brecha sería contrario a la disciplina de honestidad metodológica que rige todo el proyecto. La acción correctiva concreta y exigible antes de escalar a Fase 0 con datos reales es: **obtener validación legal peruana específica (Ley N.º 29733 y su Reglamento, más la normativa sectorial de historias clínicas que corresponda) que reemplace estos tres parámetros provisionales por cifras confirmadas con cita exacta de artículo/inciso**, incorporando dicha cita en una futura revisión de este documento. Esta verificación se añade como ítem explícito y auditable del checklist de seguridad (Anexo D, ítem 11).

4. Roles y Responsabilidades

4.1 Estructura de gobierno de seguridad

Dado que HemoScan Andino es, a la fecha de este documento, un equipo de tesis de tres integrantes sin personal dedicado exclusivamente a seguridad, este documento propone una estructura de gobierno **proporcional al tamaño real del equipo en Fase 0**, con una hoja de ruta explícita hacia una estructura más formal una vez constituida HemoScan Andino S.A.C. y alcanzada la Fase 1 (piloto pagado). Se declara honestamente que esta estructura **no sustituye** un Oficial de Seguridad de la Información (*CISO*) ni un Oficial de Protección de Datos (*DPO*) dedicados de tiempo completo, que la Ley N.º 29733 y las buenas prácticas de ISO/IEC 27001 recomendarían para una organización que trate datos de salud de menores a escala regional; se recomienda explícitamente la creación de ambos roles, aunque sea a tiempo parcial o mediante

asesoría externa contratada, como condición para escalar de la Fase 0 a la Fase 1.



4.2 Matriz RACI de procesos de seguridad

Leyenda: R = Responsable de ejecutar · A = Aprobador/rinde cuentas del resultado · C = Consultado · I = Informado · “—” = sin participación directa en este proceso.

Proceso de seguridad	Integrante 1	Integrante 2	Integrante 3	Docente asesor	Administrador del sistema / Jefatura de microred	Comité de Ética / DIRESA
Aprobación y actualización de la Política de Seguridad (Sección 3)	R	A	C	C	I	I
Gestión de altas, bajas y revisión periódica de accesos (RBAC, Política 3.1)	A	I	R	I	R	—

Proceso de seguridad	Integrante 1	Integrante 2	Integrante 3	Docente asesor	Administrador del sistema / Jefatura de microred	Comité de Ética / DIRESA
Copias de seguridad y prueba de restauración (Política 3.5)	R/A	I	C	I	I	—
Gestión de incidentes de seguridad y brechas de datos (Política 3.6)	R	A	C	I	C	I (si involucra menores)
Cumplimiento de la Ley N.º 29733 (Política 3.2)	C	R	C	C	C	A (como titular del banco de datos de salud)
Auditoría de IA y cumplimiento del DS 115-2025-PCM (Política 3.9)	C	A	R	C	I	R (verifica, rol de Auditor, CU-10)
Gestión de vulnerabilidades y parches del backend/servidor	R/A	I	C	I	I	—
Gestión criptográfica: certificados TLS, cifrado, secretos (Política 3.3)	R/A	I	C	I	I	—
Seguridad física y custodia de dispositivos de campo (Política 3.4)	R	C	I	I	R/A	—

Proceso de seguridad	Integrante 1	Integrante 2	Integrante 3	Docente asesor	Administrador del sistema / Jefatura de microred	Comité de Ética / DIRESA
Capacitación y concientización en seguridad del personal (Política 3.8)	C	R/A	C	I	C	I
Gestión de terceros e interoperabilidad externa (Política 3.10)	C	A	R	I	C	I
Revisión y mejora continua del sistema de gestión de seguridad	R	A	C	C	I	I

4.3 Justificación de la asignación de roles

La asignación anterior no es arbitraria: sigue tres criterios explícitos. **Primero**, todo proceso de naturaleza técnica-operativa (respaldo, criptografía, gestión de vulnerabilidades, dispositivos de campo) asigna la responsabilidad de ejecución (R) al **Integrante 1**, coherente con su área de competencia CE03 (Infraestructura Tecnológica, red, seguridad, centro de datos) ya declarada en la portada de este documento y con el paquete EDT 2.3 del Plan de Gestión, que le asigna literalmente la “configuración de Keycloak... y checklist de seguridad”. **Segundo**, todo proceso de naturaleza normativa o de cumplimiento (Ley N.º 29733, capacitación, gestión de terceros) asigna la responsabilidad de ejecución al **Integrante 2**, coherente con su área CE01 (Gestión de TI, diagnóstico, business case, procesos), quedando como el enlace natural con la futura figura de Oficial de Protección de Datos. **Tercero**, todo proceso embebido en el ciclo de desarrollo de software (gestión de accesos a nivel de código, auditoría de IA, gestión de terceros a nivel de integración técnica) asigna la ejecución al **Integrante 3**, coherente con su área CE02 (Ingeniería de Software).

Es importante señalar dos matices de responsabilidad que exceden la capacidad de decisión del equipo HemoScan Andino y que se reflejan deliberadamente en la matriz: **(a)** en el cumplimiento de la Ley N.º 29733, la responsabilidad final (A) recae sobre el **Comité de Ética/DIRESA**, en su calidad de titular legal del banco de datos de salud una vez exista un convenio real, mientras que HemoScan Andino ejecuta (R, vía Integrante 2) las obligaciones que le correspondan como encargada de tratamiento; y **(b)** en la auditoría de cumplimiento del DS 115-2025-PCM, el mismo Comité/DIRESA ejerce el rol de verificación externa (R en su columna, como Auditor de CU-10), sin que esto sustituya la responsabilidad clínica independiente del Personal médico sobre cada decisión individual, la cual queda fuera del alcance de esta matriz de gobernanza organizacional y se rige por su propio marco de responsabilidad profesional médica. Esta distinción evita que el documento sobre-simplifique la gobernanza de un sistema que, por diseño, involucra a actores fuera del control directo del equipo de tesis.

Anexos

Anexo A — Matriz de riesgos completa: tratamiento y riesgo residual estimado

La siguiente tabla extiende la matriz de riesgo inherente de la Sección 2.3 con la opción de tratamiento aplicada, el control principal de la Sección 3 que la implementa, y una estimación del **riesgo residual** (probabilidad e impacto recalculados asumiendo el control ya operativo), evidenciando el efecto cuantitativo esperado de las políticas de este documento.

ID	Nivel inherente (P×I)	Tratamiento (ISO 27005)	Control principal aplicado (Sección 3)	P res.	I res.	Riesgo residual	Nivel residual
RS-01	20 Crítico	Mitigar	Política 3.1, regla 4 (baja el mismo día)	1	4	4	Bajo
RS-02	15 Alto	Mitigar	Políticas 3.1 y 3.3 (RBAC + cifrado en reposo)	2	5	10	Moderado
RS-03	12 Alto	Mitigar / Transferir	Política 3.5 + SLA de hosting en Fase 1	2	4	8	Moderado
RS-04	15 Alto	Mitigar	Política 3.5 (respaldo diario + prueba trimestral)	1	5	5	Bajo
RS-05	16 Crítico	Mitigar	Política 3.4 (cifrado local + borrado remoto)	2	4	8	Moderado
RS-06	16 Crítico	Mitigar	Política 3.3, regla 3 (gestión de secretos)	1	4	4	Bajo
RS-07	10 Moderado	Mitigar	Política 3.9, regla 3 (doble validación + versionado)	1	5	5	Bajo

ID	Nivel inherente (P×I)	Tratamiento (ISO 27005)	Control principal aplicado (Sección 3)	P res.	I res.	Riesgo residual	Nivel residual
RS-08	10 Moderado	Mitigar	Política 3.1, regla 3 (MFA en roles clínicos)	1	5	5	Bajo
RS-09	12 Alto	Mitigar	Política 3.3, regla 4 (renovación automatizada)	1	4	4	Bajo
RS-10	12 Alto	Mitigar	Política 3.2, regla 3 (<i>k</i> -anonimato mínimo)	2	3	6	Moderado
RS-11	6 Moderado	Mitigar	Política 3.3, regla 6 (OTA firmado)	1	3	3	Bajo
RS-12	6 Moderado	Mitigar	Cifrado GATT reforzado (control técnico BLE)	1	3	3	Bajo
RS-13	16 Crítico	Mitigar	Política 3.8 (capacitación y concientización)	2	4	8	Moderado
RS-14	12 Alto	Mitigar	Política 3.8, regla 2 (prohibición de <i>shadow IT</i>)	2	3	6	Moderado
RS-15	8 Moderado	Evitar (hasta Fase 1/2)	ADR-08 (federado inactivo) + Política 3.9, regla 4	1	4	4	Bajo
RS-16	9 Moderado	Mitigar	Política 3.3, regla 5 + 3.7, regla 1 (revisión cruzada)	2	3	6	Moderado

ID	Nivel inherente (P×I)	Tratamiento (ISO 27005)	Control principal aplicado (Sección 3)	P res.	I res.	Riesgo residual	Nivel residual
RS-17	12 Alto	Mitigar	Política 3.9, regla 2 (registro auditable de IA)	1	4	4	Bajo
RS-18	9 Moderado	Mitigar	Procedimiento de conciliación de registros (Fase 0)	2	3	6	Moderado
RS-19	4 Bajo	Aceptar y monitorear	Política 3.10, regla 2 (verificación de proveedor)	2	2	4	Bajo

Lectura cuantitativa de conjunto: el puntaje de riesgo inherente agregado de los diecinueve escenarios suma 220 puntos; el puntaje residual estimado, tras aplicar íntegramente las políticas de la Sección 3, suma 103 puntos — una reducción aproximada del **53 %** del riesgo agregado. Se declara explícitamente que esta estimación de riesgo residual es una **proyección de diseño**, no una medición empírica: su validación real requiere que los controles descritos en la Sección 3 estén efectivamente implementados y operando, y que un ciclo de auditoría posterior (Sección 4.2, proceso de “revisión y mejora continua”) confirme o corrija estos valores con evidencia real de operación.

Anexo B — Referencias normativas y de estándares

- International Organization for Standardization / International Electrotechnical Commission. **ISO/IEC 27001:2022** — Information security, cybersecurity and privacy protection — Information security management systems — Requirements.
- International Organization for Standardization / International Electrotechnical Commission. **ISO/IEC 27002:2022** — Information security, cybersecurity and privacy protection — Information security controls.
- International Organization for Standardization / International Electrotechnical Commission. **ISO/IEC 27005:2022** — Information security, cybersecurity and privacy protection — Guidance on managing information security risks.
- National Institute of Standards and Technology. **NIST SP 800-30 Rev. 1 (2012)** — Guide for Conducting Risk Assessments.
- National Institute of Standards and Technology. **NIST Cybersecurity Framework (CSF) 2.0 (2024)**.
- Presidencia del Consejo de Ministros del Perú. **Decreto Supremo N.° 115-2025-PCM**, reglamento de la Ley N.° 31814 (Ley que promueve el uso de la Inteligencia Artificial en favor del desarrollo del país); sección salud como sector de alto riesgo, exigencia de supervisión humana y trazabilidad.
- Congreso de la República del Perú. **Ley N.° 29733**, Ley de Protección de Datos Personales.

- Ministerio de Salud del Perú. **Norma Técnica de Salud NTS 213-MINSA/DGIESP-2024** para el manejo terapéutico y preventivo de la anemia.
- Association for Computing Machinery. **Código de Ética y Conducta Profesional de la ACM (2018)**, principios 1.2, 1.6, 1.7, 2.5, 2.9 y 3.7.
- HemoScan Andino, Equipo de tesis (2026). Entregable N.º 1 — Diagnóstico Organizacional y Alineamiento Estratégico. Documento interno del proyecto, Universidad Peruana Unión, sede Juliaca.
- HemoScan Andino, Equipo de tesis (2026). Entregable N.º 2 — Business Case del Proyecto. Documento interno del proyecto, Universidad Peruana Unión, sede Juliaca.
- HemoScan Andino, Equipo de tesis (2026). Entregable N.º 3 — Plan de Gestión del Proyecto. Documento interno del proyecto, Universidad Peruana Unión, sede Juliaca.
- HemoScan Andino, Equipo de tesis (2026). Entregable N.º 5 — Requerimientos y Diseño del Sistema. Documento interno del proyecto, Universidad Peruana Unión, sede Juliaca.

Nota: las referencias a los estándares ISO/IEC 27001, 27002 y 27005, y a los marcos NIST SP 800-30 y NIST CSF 2.0, corresponden a marcos internacionales estándar y ampliamente documentados de la disciplina de gestión de seguridad de la información, por lo que se citan con confianza en su estructura general (procesos, categorías de control, funciones); los valores numéricos específicos de este documento (umbrales de k -anonimato, plazos de retención, RTO/RPO) son **propuestas de diseño del equipo**, no cifras tomadas literalmente de dichas normas, y se marcan como tales donde corresponde.

Anexo D — Checklist de seguridad de Fase 0 (operacionaliza el paquete EDT 2.3 del Plan de Gestión)

El Plan de Gestión del Proyecto (Entregable N.º 3) define el paquete EDT 2.3 (“Seguridad, identidad y control de acceso”, responsable Integrante 1) con el criterio de aceptación “al menos 3 roles funcionales probados; checklist de seguridad firmado”. Este anexo entrega dicho checklist, **actualizando el criterio de 3 a 4 roles funcionales mínimos**, en coherencia con la especificación más detallada y posterior del RNF-06 del Entregable N.º 5 (“RBAC vía Keycloak/OIDC, con al menos 4 roles funcionales distintos probados”). El checklist debe firmarse antes de autorizar el inicio de la ejecución de campo (paquete EDT 5.1 del Plan de Gestión), en la misma lógica preventiva ya anotada en el riesgo de proyecto RP8 del Entregable N.º 3.

N.º	Verificación	Responsable	Estado (a la fecha de este documento)
1	Keycloak desplegado y operativo, con al menos 4 roles funcionales distintos configurados y probados (RNF-06)	Integrante 1	Pendiente — requiere servidor desplegado (paquete EDT 2.2)
2	TLS 1.2 o superior habilitado y verificado en el backend y la plataforma web (RNF-05)	Integrante 1	Pendiente
3	Cifrado en reposo (AES-256 o equivalente) habilitado en la base de datos	Integrante 1	Pendiente

N.º	Verificación	Responsable	Estado (a la fecha de este documento)
4	Ningún secreto de configuración presente en el repositorio de código (verificación automatizada)	Integrante 1 / Integrante 3	Pendiente
5	Procedimiento de baja inmediata de cuentas ante fin de vínculo documentado y comunicado a la Jefatura de microred	Integrante 2	Pendiente — requiere convenio institucional
6	Copia de seguridad automatizada configurada, con al menos una prueba de restauración exitosa documentada	Integrante 1	Pendiente
7	Consentimiento informado digital (FHIR <i>Consent</i>) verificado como precondition obligatoria antes de cualquier captura (RN-04)	Integrante 3	Pendiente — depende de la implementación del backend
8	Registro <i>AuditEvent</i> verificado para toda recomendación generada por el componente de IA (RF-40)	Integrante 3	Pendiente
9	Capacitación de concientización en seguridad realizada al personal de salud participante de la validación	Integrante 2	Pendiente — depende del convenio y de la Fase 0
10	Este documento de Planificación de Seguridad revisado y firmado por los 3 integrantes y el docente asesor	Los 3 integrantes	Completado con la emisión de este documento , pendiente de firma física/digital

N.º	Verificación	Responsable	Estado (a la fecha de este documento)
11	Validación legal peruana de los tres parámetros pendientes de las Políticas 3.2 y 3.6 (plazo de notificación de brechas, plazo de conservación de historias clínicas, cláusulas del encargo de tratamiento — síntesis en la Sección 3.12) obtenida y citada con artículo/inciso exacto	Integrante 2	Pendiente — requiere asesoría legal especializada y convenio institucional

FIN DEL CUERPO EVALUABLE (Secciones 1 a 4 y Anexos A, B y D — rango objetivo de 10-15 páginas conforme a la plantilla del entregable). Lo que sigue a continuación es material complementario de referencia y una nota interna de cobertura, ninguno de los dos exigido por la plantilla ni sujeto a la calificación de la rúbrica CE0321.

Material complementario de referencia (fuera del cuerpo evaluable)

Este material no es exigido por la plantilla del entregable; se conserva por utilidad de consulta, pero se excluye deliberadamente del rango de 10-15 páginas del cuerpo evaluable de la Sección 1 a la Sección 4 y sus Anexos A, B y D.

Anexo C — Glosario de términos y siglas de seguridad

Sigla / término	Definición
ACM	Association for Computing Machinery, asociación profesional internacional de informática, emisora de su Código de Ética y Conducta Profesional
AES-256	Advanced Encryption Standard con clave de 256 bits, algoritmo de cifrado simétrico usado para datos en reposo
CID / CIA	Confidencialidad, Integridad y Disponibilidad; triángulo clásico de propiedades de seguridad de la información
CSF	Cybersecurity Framework, marco de ciberseguridad del NIST (versión 2.0: funciones Gobernar, Identificar, Proteger, Detectar, Responder, Recuperar)
ISMS / SGSI	<i>Information Security Management System</i> / Sistema de Gestión de Seguridad de la Información, conforme ISO/IEC 27001
ISO/IEC 27001	Norma internacional de requisitos de un sistema de gestión de seguridad de la información

Sigla / término	Definición
ISO/IEC 27005	Norma internacional de gestión de riesgos de seguridad de la información
<i>k</i> -anonimato	Propiedad de un conjunto de datos agregados en la que cada combinación de atributos identificables corresponde a al menos <i>k</i> individuos, dificultando la reidentificación
MFA	<i>Multi-Factor Authentication</i> , autenticación multifactor
NIST	National Institute of Standards and Technology, instituto de estándares tecnológicos de EE. UU., emisor de guías de gestión de riesgo (SP 800-30) y del CSF
OIDC / RBAC	OpenID Connect / Role-Based Access Control, ya definidos en el Entregable N.º 5
OTA	<i>Over-the-Air</i> , actualización remota de firmware sin conexión física al dispositivo
RACI	Responsable, Aprobador, Consultado, Informado; matriz de asignación de responsabilidades
RPO	<i>Recovery Point Objective</i> , punto objetivo de recuperación: máxima pérdida de datos tolerable medida en tiempo
RTO	<i>Recovery Time Objective</i> , tiempo objetivo de recuperación: tiempo máximo tolerable de indisponibilidad
SGSI	Ver ISMS
TLS	<i>Transport Layer Security</i> , protocolo criptográfico de cifrado de datos en tránsito
WAF	<i>Web Application Firewall</i> , cortafuegos de aplicaciones web

Anexo E — Índice de diagramas y figuras presentados en el cuerpo del documento

Figura	Descripción	Ubicación
Diagrama 1	Mapa de calor de riesgo inherente (probabilidad × impacto) de los 19 riesgos de seguridad identificados	Sección 2.4
Diagrama 2	Estructura de gobierno de seguridad de la información (Fase 0)	Sección 4.1

Nota interna de cobertura frente a la rúbrica (fuera del cuerpo evaluable)

Aclaración de alcance. Asignar un nivel de logro (“Excelente”, “Bueno”, etc.) por criterio es tarea exclusiva del docente/evaluador de la competencia CE032, no del equipo autor del entregable. Por ello, esta sección se reformuló: ya no se autoasigna una calificación por criterio; en su lugar, documenta de forma factual qué cubre el

documento y qué insumos permanecen pendientes, para que la evaluación real se apoye en evidencia verificable y no en una autocalificación.

Criterio de la rúbrica	Qué cubre el documento (evidencia verificable)	Qué permanece pendiente (no se resuelve inventando datos)
Identificación de Activos Críticos	28 activos (AC-01 a AC-28) en 7 categorías, cada uno con propietario, custodio y valoración CID justificada; síntesis de los 5 activos de máxima prioridad (Sección 1.3). Cubre los 6 tipos de activo exigidos por el enunciado (datos de salud de menores, modelo de IA y dataset propietario, claves/certificados del backend FHIR, nodos ESP32, credenciales de agentes comunitarios y personal de salud).	Contraste del inventario contra un CMDB técnico real, posible solo una vez desplegado el servidor de producción (nota añadida en Sección 1.3).
Análisis de Riesgos (ISO 27005/NIST)	Matriz de 19 riesgos (RS-01 a RS-19) con probabilidad, impacto, puntaje y nivel; mapa de calor (Sección 2.4) consistente con la tabla 2.3; tratamiento y riesgo residual estimado para los 19 riesgos (Anexo A), con suma inherente de 220, suma residual de 103 y reducción agregada de ~53 %. Metodología cruzada ISO/IEC 27005:2022, NIST SP 800-30 y NIST CSF 2.0.	Los valores de probabilidad e impacto son juicio experto del equipo, no datos empíricos de incidentes reales; su reemplazo por datos reales solo es posible una vez el sistema esté en operación (ya declarado en Anexo A).
Definición de Políticas de Seguridad	11 políticas con lineamientos numerados, parámetros técnicos concretos y control equivalente del Anexo A de ISO/IEC 27001:2022 en cada una (~25 controles citados, verificados como reales: A.5.9, A.5.15-18, A.8.24, A.5.34, A.8.13, A.5.19-22, entre otros).	Tres parámetros legales de las Políticas 3.2 y 3.6 (plazo de notificación de brechas, plazo de conservación de historias clínicas, cláusulas del encargo de tratamiento) siguen marcados [DATO PENDIENTE DE VALIDAR] ; su síntesis y la acción correctiva exigida están en la Sección 3.12 y en el ítem 11 del Anexo D. Ninguno se reemplaza por una cifra inventada.
Establecimiento de Roles y Responsabilidades	Organigrama y matriz RACI (12 procesos x 6 actores, incluidos actores externos futuros: Administrador del sistema y Comité de Ética/DIRESA), con justificación explícita de la asignación por área de competencia (Sección 4.3).	Reconocimiento explícito de que la titularidad del banco de datos de salud y la responsabilidad clínica independiente exceden el control del equipo de tesis (Sección 4.3); no se resuelve por decreto documental, sino que se declara como límite real.

Criterio de la rúbrica	Qué cubre el documento (evidencia verificable)	Qué permanece pendiente (no se resuelve inventando datos)
Calidad Documental y Ética	Integración explícita del Código de Ética y Conducta Profesional de la ACM (Sección 3.11, principios 1.2, 1.6, 1.7, 2.5, 2.9, 3.7), referencias normativas verificadas (ISO 27001/27002/27005, NIST, DS 115-2025-PCM, Ley 29733), coherencia de identificadores (AC-##, RS-##) trazable a los entregables previos. Cuerpo evaluable acotado a Secciones 1-4 y Anexos A, B y D (glosario e índice de figuras reclasificados como material complementario no exigido por la plantilla; ver más arriba).	Validación legal peruana específica de los tres parámetros de las Políticas 3.2/3.6 (Sección 3.12); un pentest técnico ejecutado sobre un ambiente desplegado; un comité de ética y un convenio institucional real. Ninguno de estos insumos existe a la fecha de este documento.

Limitación transversal declarada: cerrar por completo las brechas pendientes de la columna derecha requiere, como condición necesaria, (a) un comité de ética y un convenio institucional real que permitan validar el tratamiento de datos con una microred verdadera; (b) una prueba de penetración (*pentest*) técnica ejecutada sobre un ambiente desplegado, hoy inexistente; y (c) asesoría legal especializada en protección de datos peruana que confirme o corrija los valores marcados como **[DATO PENDIENTE DE VALIDAR]** en este documento. Ninguno de estos insumos existe a la fecha de este documento, por lo que se han declarado explícitamente en lugar de presentarse como hallazgos verificados o de rellenarse con cifras supuestas, siguiendo la misma disciplina de honestidad metodológica de los Entregables N.º 1, N.º 2, N.º 3 y N.º 5 ya presentados. La calificación final de cada criterio corresponde al docente/evaluador de la competencia CE032.